TP 6

TP 6 : Filtrer le trafic réseau avec les ACL Cisco (Standard, Étendues & Nommées)

BTS SIO – option SISR | Administration des systèmes et des réseaux

Niveau	BTS SIO option SISR – travail en binôme
Durée	6 h (cours : 1 h – TP : 5 h) – chaque partie du TP indique sa durée conseillée
Outil	Cisco Packet Tracer (8.x recommandé)
Prérequis	TP01 (réseau local : DHCP, DNS, HTTP, routeurs) adressage IPv4 et masques. routage statique de base
Compétences visées	B2.2 Installer, tester et déployer une solution d'infrastructure réseau. B2.3 Exploiter, dépanner et superviser une solution d'infrastructure réseau. Bloc 3 : cybersécurité (sécurisation d'une infrastructure réseau)
À rendre	Mathis Dubos – BTS SIO SISR (2ème Année)

CONSIGNE

Comme pour le TP01 : **capturez chaque étape dans votre compte-rendu Word** (commande saisie + résultat obtenu).

Ce TP est une excellente source pour alimenter votre **portfolio** (thème : sécurisation d'une infrastructure réseau).

Sommaire

Chapitre	Contenu
Chapitre 1 – Cours	1 : pourquoi filtrer 2 : qu'est-ce qu'une ACL 3 : comment le routeur la lit 4 : types d'ACL 5 : wildcard mask 6 : syntaxe 7 : placement et sens 8 : créer et modifier 9 : méthode de conception 10 : limites et bonnes pratiques 11 : questions flash
Annexe	Aide-mémoire ACL (à garder sous les yeux pendant le TP)

Chapitre 1 – Cours : les Access Control Lists (ACL)

OBJECTIF
Ce chapitre vous donne **tout ce qu'il faut savoir** pour réussir le TP : le besoin, le fonctionnement, la syntaxe, le placement et la méthode. Lisez-le **avant** la partie A. Comptez environ 1 h (lecture + questions flash finales).

1 Pourquoi filtrer le trafic ?

Par défaut, un routeur est **poli** : dès qu'il connaît une route vers la destination, il transmet le paquet, sans se demander qui l'envoie ni pourquoi. C'est le comportement voulu pour un réseau qui marche… mais c'est aussi une faille de sécurité. Sans filtrage :

- un poste infecté du service Marketing peut **scanner** et attaquer les serveurs de l'entreprise ;
- un visiteur branché sur le Wi-Fi invité peut **atteindre** les postes de la comptabilité ;
- n'importe quel utilisateur peut tenter de **se connecter en administrateur** sur un routeur.

Il faut donc pouvoir décider **qui a le droit de parler à qui, et pour quel service**. Sur les équipements Cisco, l'outil de base pour cela est l'**ACL** (*Access Control List*, liste de contrôle d'accès).

Utilité	Exemple concret
Cloisonner les réseaux	Le réseau des invités ne doit pas atteindre le réseau des serveurs.
Protéger des serveurs	Seuls HTTP et HTTPS sont ouverts vers le serveur web ; tout le reste est fermé.
Réduire la surface d'attaque	Interdire Telnet (port 23, non chiffré) ou le partage de fichiers SMB vers l'extérieur.
Protéger l'administration	Seul le poste de l'administrateur peut ouvrir une session Telnet/SSH sur le routeur.
Faire respecter une politique	Le service Compta n'accède qu'aux serveurs dont il a besoin.
Limiter des flux inutiles	Empêcher les *pings* (ICMP) depuis une zone non fiable pour compliquer la cartographie du réseau.
Désigner du trafic pour une autre fonction	La même syntaxe sert à choisir le trafic à traduire (NAT), à chiffrer (VPN) ou à prioriser (QoS).

PLACE DES ACL DANS LA SÉCURITÉ
Une ACL est un filtre **simple, gratuit et présent sur tous les routeurs** et switchs de niveau 3. Elle travaille aux couches **3 (IP)** et **4 (TCP/UDP)**. Elle ne remplace pas un **pare-feu** (pas de suivi des connexions, pas d'analyse du contenu) mais elle en est la première brique, dans une logique de **défense en profondeur** (ACL + VLAN + pare-feu + authentification…).

2 Qu'est-ce qu'une ACL ?

Une ACL est une **liste ordonnée de règles**. Chaque règle (appelée **ACE** – *Access Control Entry*) associe :

- une **action** : `permit` (autoriser) ou `deny` (refuser) ;
- des **critères** de correspondance : adresse source, adresse destination, protocole, ports…

Une ACL **n'a aucun effet tant qu'elle n'est pas appliquée** : il faut la lier à une interface (ou à des lignes VTY) et préciser un sens (`in` ou `out`).

L'IMAGE DU VIGILE

Imaginez un vigile devant une salle, avec une liste. Il lit la liste **de haut en bas**. Dès qu'un visiteur correspond à une ligne, il applique la consigne de cette ligne (« entre » ou « dehors ») et ne lit pas la suite. Si le visiteur ne figure sur **aucune** ligne, la consigne finale est : **refusé**.

Anatomie d'une règle

```
access-list 101 deny tcp 192.168.1.0 0.0.0.255 host 172.16.1.100 eq 21
```

Morceau	Rôle	Signification ici
`access-list`	Commande	Ajoute une règle à une ACL numérotée
`101`	Identifiant de l'ACL	ACL étendue (100 à 199)
`deny`	Action	Refuser les paquets qui correspondent
`tcp`	Protocole	Seulement le trafic TCP
`192.168.1.0 0.0.0.255`	Source + wildcard	Tout le réseau 192.168.1.0/24
`host 172.16.1.100`	Destination	Uniquement cette machine
`eq 21`	Port de destination	Port 21 (FTP)

Traduction en français : « refuser le TCP venant du réseau 192.168.1.0/24 et allant vers 172.16.1.100 sur le port 21 (FTP) ».

Vocabulaire à connaître

Terme	Définition
ACL	Liste ordonnée de règles de filtrage.
ACE / règle	Une ligne de l'ACL : action + critères.
permit / deny	Autoriser / refuser.
Wildcard mask	Masque « inversé » qui indique quels bits de l'adresse comparer (voir cours 5).
Inbound (in) / outbound (out)	Sens d'application, vu du **routeur** : paquet qui entre / qui sort par l'interface.
Deny implicite	Règle invisible ajoutée à la fin de toute ACL : `deny ip any any`.
Stateless (sans état)	Le routeur juge chaque paquet isolément, sans mémoire de la connexion.
Trafic de transit	Trafic qui traverse le routeur (celui que filtrent les ACL). À distinguer du trafic **généré par** le routeur.

3 Comment le routeur lit une ACL

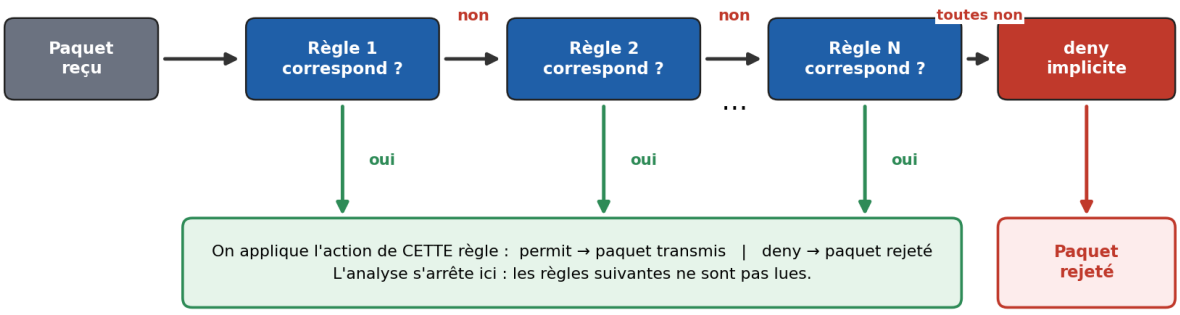


Figure 1 – Algorithme de lecture d'une ACL

Quatre principes à connaître par cœur :

1. **Lecture séquentielle** : le routeur teste les règles dans l'ordre où elles ont été écrites.
2. **Première correspondance** : dès qu'une règle correspond, son action est appliquée et la lecture **s'arrête**. L'ordre des règles est donc **capital**.
3. **Deny implicite** : si aucune règle ne correspond, le paquet est refusé. Une ACL qui ne contient que des `deny` bloque donc **tout** le trafic.
4. **Absence d'état** : chaque paquet est jugé seul. La réponse à une requête autorisée n'est pas automatiquement autorisée.

Exemple guidé : suivre cinq paquets

```
access-list 120 deny tcp 192.168.1.0 0.0.0.255 host 172.16.1.100 eq 21
access-list 120 permit tcp 192.168.1.0 0.0.0.255 any eq 80
access-list 120 permit icmp any any
```

Les trois règles sont numérotées 1, 2 et 3 dans l'ordre d'écriture.

N°	Paquet	Règle qui correspond	Résultat
1	TCP de 192.168.1.111 vers 172.16.1.100, port 21	Règle 1	**Refusé (deny)**
2	TCP de 192.168.1.111 vers 172.16.1.100, port 80	Règle 2 (la règle 1 ne correspond pas : port différent)	**Autorisé**
3	ICMP de 192.168.1.10 vers 172.16.1.10	Règle 3	**Autorisé**
4	TCP de 192.168.1.10 vers 172.16.1.100, port 443	Aucune	**Refusé (deny implicite)**
5	UDP de 192.168.1.10 vers 172.16.1.100, port 53	Aucune	**Refusé (deny implicite)**

L'ORDRE FAIT LE RÉSULTAT

Si l'on plaçait en première position la règle `permit tcp 192.168.1.0 0.0.0.255 any`, le paquet 1 (FTP vers 172.16.1.100) serait **autorisé** : la règle `deny` ne serait jamais atteinte. Dès qu'une règle générale précède une règle spécifique qui la contredit, la règle spécifique est ignorée. Toujours écrire du **plus précis au plus général**.

Où l'ACL intervient dans le routeur

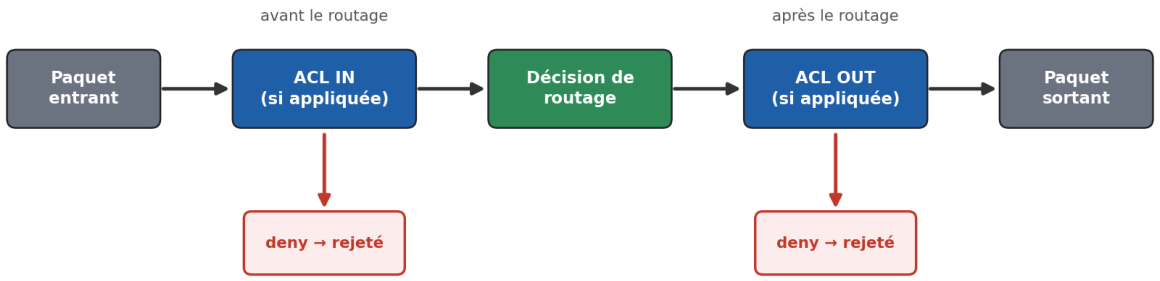


Figure 2 – Trajet d'un paquet et positions des ACL

- Une ACL `**in**` est évaluée **avant** la décision de routage : un paquet refusé n'est même pas routé (économie de ressources).
- Une ACL `**out**` est évaluée **après** la décision de routage, juste avant que le paquet quitte le routeur.
- Une ACL ne filtre **jamais le trafic généré par le routeur** (par exemple un `ping` lancé depuis le routeur), mais une ACL `in` filtre le trafic **destiné** au routeur (ping vers son adresse, Telnet, SSH…).
- Quand un paquet est refusé, le routeur peut renvoyer à l'émetteur un message ICMP « destination unreachable (administratively prohibited) » : c'est ce que vous voyez côté poste.

4 Les types d'ACL

	ACL standard	ACL étendue
Numéros	1 à 99 et 1300 à 1999	100 à 199 et 2000 à 2699
Critère(s)	Adresse **source** uniquement	Protocole, source, destination, ports TCP/UDP, type ICMP, options
Précision	Faible : tout ou rien pour une source	Élevée : on peut viser un service précis
Usage typique	Bloquer/autoriser un poste ou un réseau ; filtrer l'accès aux lignes VTY	Autoriser un service, interdire un protocole, protéger un serveur
Placement	Au plus **près de la destination**	Au plus **près de la source**

Numérotée ou nommée ?

Quel que soit son type, une ACL peut être **numérotée** (identifiée par un numéro) ou **nommée** (identifiée par un nom explicite). Les ACL nommées sont recommandées aujourd'hui.

	ACL numérotée	ACL nommée
Création	`access-list 100 permit …` (une commande par ligne)	`ip access-list extended NOM` puis les règles dans un sous-mode
Lisibilité	Faible (`100`, `101`… : que filtre-t-elle ?)	Bonne (`FILTRE_LAN`, `AGENCE_IN`)
Modification	Ajout en fin de liste seulement ; pour changer l'ordre, il faut tout recréer	Insertion et suppression d'une ligne grâce aux **numéros de séquence**

POUR LA CULTURE (HORS PROGRAMME)
Il existe d'autres familles d'ACL : **réflexives** (autorisent automatiquement le retour d'une connexion initiée de l'intérieur), **dynamiques** (accès temporaire après authentification), **temporelles** (`time-range` : actives à certaines heures) et **IPv6** (toujours nommées). Ce TP se concentre sur les ACL standard et étendues IPv4.

5 Le wildcard mask en détail

Dans une ACL, on ne donne pas un masque de sous-réseau mais un **wildcard mask** (masque générique). Il indique, bit par bit, ce que le routeur doit comparer :

- bit à **0** → le bit de l'adresse **doit être identique** ;
- bit à **1** → le bit est **ignoré** (« peu importe »).

Calcul rapide : wildcard = `255.255.255.255` – masque de sous-réseau. Exemple : pour un /26 (255.255.255.192), le wildcard est 255.255.255.255 – 255.255.255.192 = **0.0.0.63**.

MOYEN MNÉMOTECHNIQUE
Pour un bloc d'adresses aligné, le wildcard de l'octet concerné vaut **(nombre d'adresses du bloc) – 1**. Un /28 contient 16 adresses → wildcard **0.0.0.15**. Un /30 en contient 4 → **0.0.0.3**. Un /25 en contient 128 → **0.0.0.127**.

Exemple détaillé : 192.168.1.32 0.0.0.15

	Dernier octet en binaire	Décimal
Adresse	0010 0000	32
Wildcard	0000 1111	15
Bits comparés (0)	0010 ???? → les 4 premiers bits doivent valoir 0010	–
Plage obtenue	0010 0000 → 0010 1111	**32 à 47**

La règle concerne donc les adresses **192.168.1.32 à 192.168.1.47** (un bloc /28).

Écriture dans l'ACL	Adresses concernées	Équivalent CIDR
`192.168.1.0 0.0.0.255`	192.168.1.0 à 192.168.1.255	/24
`192.168.1.128 0.0.0.127`	192.168.1.128 à 192.168.1.255	/25
`192.168.1.32 0.0.0.15`	192.168.1.32 à 192.168.1.47	/28
`10.1.4.0 0.0.3.255`	10.1.4.0 à 10.1.7.255	/22
`172.16.0.0 0.0.255.255`	172.16.0.0 à 172.16.255.255	/16
`host 192.168.1.10` ≡ `192.168.1.10 0.0.0.0`	Une seule adresse	/32
`any` ≡ `0.0.0.0 255.255.255.255`	Toutes les adresses	/0

ERREUR CLASSIQUE
Écrire le **masque** (`255.255.255.0`) à la place du **wildcard** (`0.0.0.255`). Le routeur l'accepte sans erreur… mais la règle ne correspond plus à ce que vous croyez (voir partie G, cas 3).

6 La syntaxe en détail

6.1 – ACL standard

```
Router(config)# access-list <1-99> {permit | deny} {host <IP> | <réseau> <wildcard> | any}
```

Exemple	Signification
`access-list 10 permit 192.168.1.0 0.0.0.255`	Autorise le réseau 192.168.1.0/24 (le reste est refusé par le deny implicite).
`access-list 10 deny host 192.168.1.112`	Refuse le poste 192.168.1.112.
`access-list 10 permit any`	Autorise toutes les autres sources.
`access-list 11 permit 192.168.1.10`	Forme abrégée : une adresse sans wildcard équivaut à `host`.

6.2 – ACL étendue

```
Router(config)# access-list <100-199> {permit | deny} <protocole>
                    <source> <wildcard-src>  [opérateur port-src]
                    <destination> <wildcard-dst>  [opérateur port-dst]  [option]
```

Champ	Valeurs	Remarques
Protocole	`ip`, `tcp`, `udp`, `icmp` (et d'autres protocoles IP)	`ip` = tous les protocoles : on ne peut alors pas utiliser de ports.
Source / destination	`host <IP>`, `<réseau> <wildcard>`, `any`	La source vient **toujours avant** la destination.
Opérateur de port	`eq` égal – `neq` différent – `lt` inférieur – `gt` supérieur – `range <min> <max>`	Uniquement avec `tcp` et `udp`.
Option	`established`, `echo`, `echo-reply`, `log`…	Voir ci-dessous.

PORT SOURCE OU PORT DESTINATION ?

La position de l'opérateur de port compte : **juste après la source**, il filtre le **port source** ; **juste après la destination**, il filtre le **port destination**. Un client utilise un port source aléatoire (> 1023) et contacte un port de destination connu : on filtre donc presque toujours le port **destination**.

```
! Requêtes HTTP vers le serveur (port destination 80)
access-list 101 permit tcp any host 172.16.1.100 eq 80
! Réponses du serveur (port source 80)
access-list 102 permit tcp host 172.16.1.100 eq 80 any
```

Ports et protocoles courants

Service	Protocole / port	Service	Protocole / port
FTP (données / contrôle)	TCP 20 / 21	HTTPS	TCP 443
SSH	TCP 22	SMB (partage Windows)	TCP 445
Telnet	TCP 23	RDP (bureau à distance)	TCP 3389
SMTP (envoi de mail)	TCP 25	DHCP (serveur / client)	UDP 67 / 68

Service	Protocole / port	Service	Protocole / port
DNS	UDP 53 (et TCP 53)	TFTP	UDP 69
HTTP (`www`)	TCP 80	SNMP	UDP 161
POP3 / IMAP	TCP 110 / 143	NTP	UDP 123

Cisco accepte aussi des noms à la place des numéros (`eq www`, `eq ftp`, `eq domain`…). Dans `show access-lists`, IOS les réécrit avec ces noms.

Les options à connaître

Option	Utilisation
`established`	TCP uniquement. Correspond aux segments qui portent le drapeau **ACK** ou **RST**, c'est-à-dire les paquets qui **suivent** l'ouverture d'une connexion (réponses). Un premier paquet de connexion (SYN seul) ne correspond pas.
`echo` / `echo-reply`	ICMP. Demande de ping (type 8) / réponse de ping (type 0). Permet de filtrer les demandes sans bloquer les réponses.
`unreachable`, `time-exceeded`	ICMP. « Destination inaccessible » et « TTL dépassé » (utilisé par `traceroute`).
`log`	Journalise chaque correspondance de la règle (utile pour repérer des tentatives d'accès).
`remark <texte>`	Commentaire pour documenter l'ACL (n'est pas une règle).

Exemples commentés

Besoin	Règle
Interdire le HTTP du LAN vers un serveur	`access-list 101 deny tcp 192.168.1.0 0.0.0.255 host 10.0.0.10 eq 80`
Autoriser le HTTPS d'un seul poste vers n'importe où	`access-list 102 permit tcp host 192.168.1.10 any eq 443`
Bloquer les pings vers un serveur	`access-list 103 deny icmp any host 10.0.0.10`
Bloquer les demandes de ping mais pas les réponses	`access-list 103 deny icmp any any echo`
Interdire Telnet partout	`access-list 104 deny tcp any any eq 23`
N'autoriser SSH que depuis le poste d'administration	`access-list 105 permit tcp host 192.168.1.10 any eq 22`
Autoriser FTP (contrôle et données actives)	`access-list 106 permit tcp any host 10.0.0.10 range 20 21`
Refuser tous les ports sauf 80 vers un serveur	`access-list 107 permit tcp any host 10.0.0.10 eq 80` puis `access-list 107 deny ip any host 10.0.0.10`
Refuser tous les ports supérieurs à 1023 vers un serveur	`access-list 108 deny tcp any host 10.0.0.10 gt 1023`

6.3 – Application

```
Router(config)# interface <interface>
Router(config-if)# ip access-group <numéro | nom> {in | out}

! Cas particulier : accès distants au routeur
Router(config)# line vty 0 4
Router(config-line)# access-class <numéro> in
```

Pour les **interfaces**, on utilise `ip access-group` ; pour les **lignes VTY** (Telnet/SSH vers le routeur), on utilise `access-class`.

7 Où et dans quel sens appliquer une ACL ?

Le sens (in / out) se juge du point de vue du routeur

`in` : le paquet **entre** dans le routeur par cette interface. **`out`** : le paquet **sort** du routeur par cette interface. Pour une même conversation, le paquet aller et le paquet retour ne traversent donc pas les interfaces dans le même sens : ce qui est `in` à l'aller devient `out` au retour sur la même interface.

Règles de placement

	Où ?	Pourquoi ?
ACL standard	Au plus **près de la destination**	Elle ne voit que la source. Placée près de la source, elle bloquerait cette source vers **toutes** les destinations.
ACL étendue	Au plus **près de la source**	Elle est précise : on stoppe le trafic indésirable le plus tôt possible, sans le faire traverser le réseau pour rien.

Exemple 1 – ACL standard : interdire un réseau vers un autre

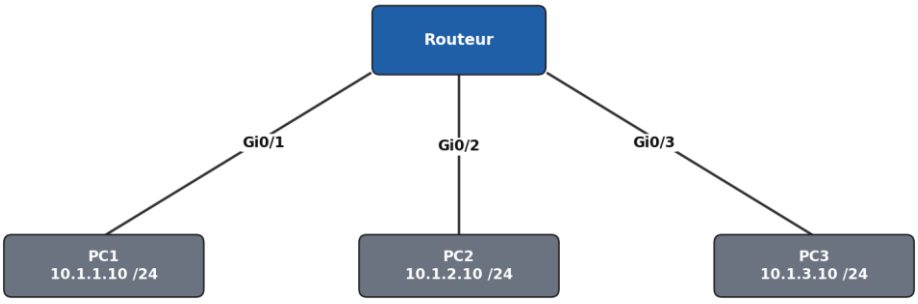


Figure 3 – Trois réseaux reliés à un même routeur

Besoin : le réseau 10.1.1.0/24 (PC1) ne doit pas communiquer avec 10.1.2.0/24 (PC2), mais doit continuer à joindre 10.1.3.0/24 (PC3).

Choix : ACL **standard** (seule la source compte), placée au plus près de la destination, donc sur l'interface **Gi0/2**, dans le sens **out** (le trafic sort vers PC2).

```
Router(config)# access-list 1 deny 10.1.1.0 0.0.0.255
Router(config)# access-list 1 permit any
Router(config)# interface gigabitEthernet 0/2
Router(config-if)# ip access-group 1 out
```

La ligne `permit any` est indispensable : sinon le `deny` implicite bloquerait aussi PC3 vers PC2. Si l'on avait placé cette ACL sur Gi0/1 en `in`, PC1 aurait été bloqué vers **tous** les réseaux, PC3 compris.

Exemple 2 – ACL étendue : interdire le ping d'un réseau vers un autre

Besoin : PC3 ne doit plus pouvoir **pinguer** PC2, PC1 le peut toujours. **Choix** : ACL **étendue** (protocole ICMP), au plus près de la source, donc **Gi0/3** en sens **in**.

```
Router(config)# access-list 100 deny icmp 10.1.3.0 0.0.0.255 10.1.2.0 0.0.0.255
Router(config)# access-list 100 permit ip any any
Router(config)# interface gigabitEthernet 0/3
Router(config-if)# ip access-group 100 in
```

UNE SEULE ACL PAR INTERFACE, PAR SENS, PAR PROTOCOLE

Appliquer une seconde ACL dans le même sens sur la même interface **remplace** la première. Si vous avez plusieurs besoins sur un même sens, il faut **fusionner** toutes les règles dans une seule ACL (c'est l'objet de la partie E).

8 Créer, lire et modifier une ACL

ACL numérotée : ajout seulement en fin de liste

Chaque commande `access-list <n°> …` ajoute la règle **à la fin**. On ne peut pas en insérer une au milieu ni en supprimer une seule : pour corriger un ordre, on supprime toute l'ACL (`no access-list <n°>`) et on la recrée. Astuce : préparez vos règles dans un éditeur de texte puis collez-les.

ACL nommée : numéros de séquence

```
Router(config)# ip access-list extended FILTRE_LAN
Router(config-ext-nacl)# deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3
Router(config-ext-nacl)# permit ip any any

Router# show access-lists FILTRE_LAN
Extended IP access list FILTRE_LAN
    10 deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3 (4 match(es))
    20 permit ip any any (37 match(es))
```

IOS numérote les règles de 10 en 10. Ces numéros servent à **repérer**, **insérer** et **supprimer** des lignes ; le nombre entre parenthèses est le **compteur de correspondances**, précieux pour vérifier qu'une règle est bien utilisée.

Je veux…	Commande (dans le mode de l'ACL nommée)
Ajouter une règle **à la fin**	`permit …` (sans numéro)
Insérer une règle entre 10 et 20	`15 deny …`
Supprimer une ligne	`no 15`
Commenter l'ACL	`remark Bloque le ping vers l'interconnexion`
Supprimer toute l'ACL	`no ip access-list extended NOM` (mode global)
Retirer l'ACL d'une interface sans la supprimer	`no ip access-group NOM in` (mode interface)

MODIFIER UNE ACL EN PRODUCTION

Supprimer puis recréer une ACL **ligne par ligne** alors qu'elle est appliquée peut couper brutalement le trafic : après la première ligne `deny`, le `deny` implicite bloque tout le reste. Bonne pratique : **construire la nouvelle ACL sous un autre nom**, puis basculer l'interface d'un coup avec `ip access-group NOUVEAU_NOM in`.

9 Méthode pour concevoir une ACL

1. **Formuler le besoin en français** : qui (source) peut faire quoi (protocole/port) vers quoi (destination) ?
2. **Repérer les flux** dans les deux sens (aller **et retour**) et les flux annexes indispensables (DNS, DHCP…).
3. **Choisir le type, le routeur, l'interface et le sens** (règles de placement).
4. **Écrire les règles** du plus précis au plus général, en décidant du sort du trafic restant (`permit ip any any` ou `deny` implicite).
5. **Appliquer, tester (cas autorisés ET cas interdits), vérifier les compteurs, documenter.**

Exemple complet

Besoin : dans une PME, le réseau **Compta** (192.168.10.0/24) doit pouvoir joindre uniquement : le serveur de fichiers 192.168.50.10 (SMB, TCP 445), le serveur web interne 192.168.50.20 (HTTP et HTTPS) et le serveur DNS 192.168.50.53 (UDP 53). Le reste du réseau Serveurs (192.168.50.0/24) lui est interdit. Tout autre trafic de la Compta (Internet…) reste autorisé.

- **Flux** : Compta → serveurs (requêtes). Le retour est géré par le routeur des serveurs, hors ACL ici. On n'oublie pas le **DNS**, sinon la résolution de noms casse.
- **Type** : étendue (ports). **Placement** : près de la source → interface Compta du routeur (`Gi0/1`), sens **in**.
- **Ordre** : autorisations précises d'abord, interdiction générale du réseau Serveurs ensuite, `permit ip any any` à la fin.

```
ip access-list extended COMPTA_IN
 remark Compta : acces limite aux serveurs necessaires
 permit tcp 192.168.10.0 0.0.0.255 host 192.168.50.10 eq 445
 permit tcp 192.168.10.0 0.0.0.255 host 192.168.50.20 eq 80
 permit tcp 192.168.10.0 0.0.0.255 host 192.168.50.20 eq 443
 permit udp 192.168.10.0 0.0.0.255 host 192.168.50.53 eq 53
 deny ip 192.168.10.0 0.0.0.255 192.168.50.0 0.0.0.255
 permit ip any any
!
interface gigabitEthernet 0/1
 ip access-group COMPTA_IN in
```

Tests à prévoir : cas autorisés (accès SMB, page web, résolution DNS) **et** cas interdits (Telnet vers 192.168.50.10, ping vers 192.168.50.20, accès à un autre serveur du réseau 192.168.50.0/24), puis `show access-lists COMPTA_IN` pour contrôler les compteurs.

Cours 10 Limites et bonnes pratiques

Limites

- **Sans état** : la réponse à une requête autorisée doit être autorisée explicitement (mot-clé `established` pour TCP, `echo-reply` pour ICMP). Pour un vrai suivi des connexions, il faut un **pare-feu à états**.
- **Filtrage par adresse IP** : une adresse se change ou s'usurpe ; en DHCP elle varie. On préfère filtrer par **réseau** (VLAN, sous-réseau de rôle) que par poste.
- **Pas d'analyse applicative** : une ACL ne sait pas distinguer un site légitime d'un site malveillant sur le port 443.
- **Complexité** : plus une ACL grossit, plus elle est difficile à maintenir et à auditer.

Bonnes pratiques

- **Documenter** chaque ACL (`remark`, nom explicite) et conserver la politique de sécurité qui la justifie.
- **Précis d'abord, général ensuite** ; ne mettre `permit ip any any` en fin d'ACL que si l'on raisonne en « liste noire ». En zone sensible, préférer une **liste blanche** (tout refuser sauf le nécessaire).
- **Tester avant de généraliser** : cas autorisés ET interdits, puis test de non-régression après chaque modification.
- **Ne pas se couper l'accès** : lors du filtrage de Telnet/SSH, garder un accès par la console.
- **Sauvegarder** la configuration (`copy running-config startup-config`) et l'ACL avant modification.
- **Combiner** les protections : ACL + segmentation VLAN + pare-feu + authentification.

Cours 11 Questions flash (auto-évaluation)

Répondez sans regarder le cours ; le corrigé est fourni à votre enseignant.

N°	Question	Réponses proposées	Réponse & Justification validée
1	Une ACL ne contient que la ligne `deny icmp any any` et est appliquée sur une interface. Que devient le trafic TCP ?	a) Il passe b) Il est bloqué c) Cela dépend du port	**b) Il est bloqué :** À cause du 'deny ip any any' implicite final présent dans toute ACL. Tout trafic non explicitement permis (ici TCP) est détruit.
2	Quel est le wildcard du réseau 192.168.10.64/26 ?	a) 0.0.0.63 b) 0.0.0.64 c) 255.255.255.192	**a) 0.0.0.63 :** Masque /26 = 255.255.255.192. Wildcard = 255.255.255.255 - 255.255.255.192 = 0.0.0.63.
3	Sur quoi une ACL standard filtre-t-elle ?	a) La source b) La source et la destination c) La destination et le port	**a) La source :** Une ACL standard (1-99) ne filtre exclusivement que sur l'adresse IP source du paquet.
4	Où place-t-on une ACL étendue ?	a) Près de la destination b) Près de la source c) Sur n'importe quel routeur	**b) Près de la source :** L'ACL étendue étant très précise (IP src/dst, ports), on la place au plus près de la source pour éliminer le trafic indésirable dès l'entrée et épargner la bande passante WAN.
5	Plusieurs règles correspondent à un paquet. Laquelle s'applique ?	a) La plus précise b) La première dans la liste c) Toutes	**b) La première dans la liste :** Traitement séquentiel 'first-match' de haut en bas ; dès qu'une règle correspond, l'action (permit/deny) s'exécute et le routeur stoppe l'analyse.
6	Un `ping` est lancé depuis le routeur R1. Une ACL `out` de R1 refuse l'ICMP. Le ping est-il bloqué ?	a) Oui b) Non, le trafic généré par le routeur n'est pas filtré c) Seulement la réponse	**b) Non, le trafic généré par le routeur n'est pas filtré :** Les paquets créés localement par l'OS du routeur (ex: ping depuis CLI) ne traversent pas les filtres ACL sortants.

N°	Question	Réponses proposées	Réponse & Justification validée
7	Dans `permit tcp any host 10.0.0.10 eq 443`, que filtre `eq 443` ?	a) Le port source b) Le port destination c) Les deux	**b) Le port destination :** Positionné après l'adresse destination host 10.0.0.10, eq 443 cible le port de destination TCP (HTTPS).
8	Combien d'ACL IPv4 entrantes peut-on appliquer sur une interface ?	a) 1 b) 2 c) Autant qu'on veut	**a) 1 :** Règle absolue Cisco : au maximum 1 seule ACL par interface, par sens (in ou out) et par protocole (IPv4).
9	Quelle commande affiche les ACL et leurs compteurs de correspondances ?	a) `show ip route` b) `show access-lists` c) `show ip interface brief`	**b) show access-lists :** Affiche la totalité des règles d'ACL configurées ainsi que les compteurs de correspondances (matches).
10	Quel mot-clé reconnaît les réponses d'une connexion TCP initiée de l'intérieur ?	a) `established` b) `log` c) `remark`	**a) established :** Permet de reconnaître les paquets TCP dont les drapeaux ACK ou RST sont positionnés (réponses à des sessions ouvertes de l'intérieur).

Travaux pratiques

1. Contexte et objectifs

Vous êtes technicien(ne) réseau dans l'entreprise fictive **SISR2** (domaine `sisr2.local`). Le **siège** (LAN 192.168.1.0/24 : serveurs DHCP, DNS et Web) est relié par une liaison série 1.1.1.0/30 à une **agence** (LAN 172.16.1.0/24). Suite à un audit, le RSSI vous transmet la politique de filtrage suivante. Votre mission : **la traduire en ACL Cisco**, la tester, puis la documenter.

Règle	Énoncé de la politique de sécurité
R1	Les postes du LAN du siège ne doivent pas pouvoir envoyer de **ping** vers le réseau d'interconnexion **1.1.1.0/30**.
R2	**PC2** (192.168.1.112) ne doit avoir **aucun accès** au réseau de l'agence.
R3	Depuis le LAN du siège, le **Serveur-Agence** (172.16.1.100) n'est accessible qu'en **HTTP**. Le reste de l'agence (ex. PC3) reste joignable normalement.
R4	Depuis l'agence, seuls sont autorisés vers le siège : le **serveur Web** (HTTP) et le **serveur DNS** (DNS). Les **réponses** aux connexions initiées depuis le siège doivent continuer à passer.

Objectifs pédagogiques

À l'issue du TP, vous serez capable de :

- expliquer le rôle d'une ACL et **l'ordre dans lequel le routeur la lit** (règles évaluées de haut en bas, `deny` implicite final) ;
- **calculer un wildcard mask** et lire une règle d'ACL ;
- choisir le **type** (standard / étendue), le **routeur**, l'**interface** et le **sens** (`in` / `out`) adaptés à un besoin ;
- écrire, appliquer, tester et vérifier une ACL **numérotée** puis **nommée**, et la modifier sans tout recréer ;
- **diagnostiquer et corriger** une ACL défaillante ;
- identifier les **limites** des ACL (filtrage sans état, adresses IP dynamiques).

2. Topologie et plan d'adressage.

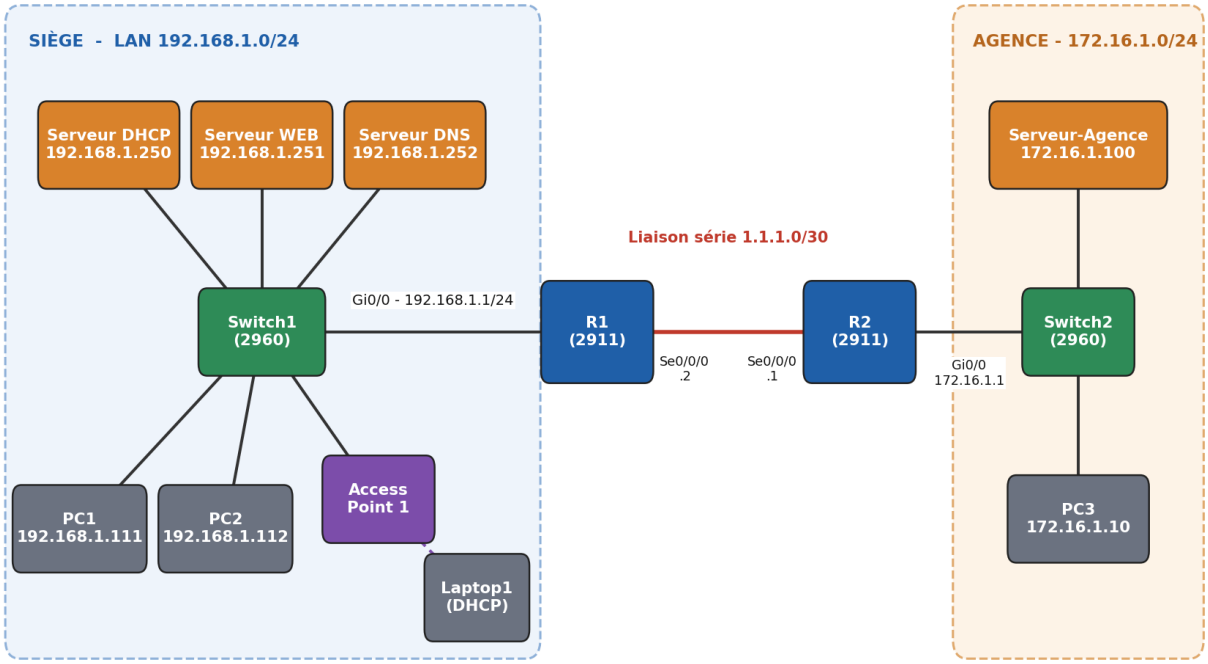


Figure 4 – Topologie du TP02

Équipement	Interface	Adresse IP / masque	Passerelle	Remarque
R1	Gi0/0	192.168.1.1 /24	–	Vers Switch1 (LAN siège)
R1	Se0/0/0	1.1.1.2 /30	–	Vers R2
R2	Se0/0/0	1.1.1.1 /30	–	Vers R1
R2	Gi0/0	172.16.1.1 /24	–	Vers Switch2 (agence)
Serveur DHCP	Fa0	192.168.1.250 /24	192.168.1.1	Pool 192.168.1.10 → .110
Serveur WEB	Fa0	192.168.1.251 /24	192.168.1.1	www.sisr2.local
Serveur DNS	Fa0	192.168.1.252 /24	192.168.1.1	www.sisr2.local → .251
PC1	Fa0	192.168.1.111 /24	192.168.1.1	**IP statique** (hors pool), DNS .252
PC2	Fa0	192.168.1.112 /24	192.168.1.1	**IP statique** (hors pool), DNS .252
Laptop1	Wi-Fi	DHCP	192.168.1.1	Via Access Point 1
PC3	Fa0	172.16.1.10 /24	172.16.1.1	DNS 192.168.1.252
Serveur-Agence	Fa0	172.16.1.100 /24	172.16.1.1	Services HTTP et FTP activés

POURQUOI PC1 ET PC2 EN IP STATIQUE ?
Une ACL filtre sur des **adresses IP**. Si PC2 obtenait son adresse par DHCP, elle pourrait changer et la règle « bloquer PC2 » ne s'appliquerait plus au bon poste. Vous reviendrez sur cette limite en partie C et dans le bilan.

Partie A – Préparer l'environnement (30 min)

A1. Créez la base : Switch1, serveurs, PC1, PC2, Access Point, Laptop1, R1 et R2). **Ajoutez** un **Switch2 (2960)** relié à l'interface Gi0/0 de R2, puis **PC3** et **Serveur-Agence** reliés à Switch2.

> **RAPPEL**
> Un routeur 2911 n'a pas de port série par défaut : **éteignez-le**, ajoutez un module **HWIC-2T**, puis rallumez-le. Utilisez un câble **série DCE** entre R1 et R2. La commande `clock rate` se saisit uniquement sur l'extrémité **DCE** (petite horloge sur le câble) ; ci-dessous on suppose que c'est R1.

A2. Configurez les équipements selon le plan d'adressage. Sur **Serveur-Agence**, activez les services **HTTP** et **FTP** (Services → FTP : utilisateur `cisco`, mot de passe `cisco`). Passez PC1 et PC2 en IP statique (avec DNS 192.168.1.252) ; Laptop1 reste en DHCP.

A3. Configurez les routeurs (extrait à saisir en mode CLI) :

Routeur R1

```
Router> enable
Router# configure terminal
Router(config)# hostname R1
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# ip address 192.168.1.1 255.255.255.0
R1(config-if)# no shutdown
R1(config-if)# exit
R1(config)# interface serial 0/0/0
R1(config-if)# ip address 1.1.1.2 255.255.255.252
R1(config-if)# clock rate 64000
R1(config-if)# no shutdown
R1(config-if)# exit
R1(config)# ip route 172.16.1.0 255.255.255.0 1.1.1.1
```

Routeur R2

```
Router> enable
Router# configure terminal
Router(config)# hostname R2
R2(config)# interface serial 0/0/0
R2(config-if)# ip address 1.1.1.1 255.255.255.252
R2(config-if)# no shutdown
R2(config-if)# exit
R2(config)# interface gigabitEthernet 0/0
R2(config-if)# ip address 172.16.1.1 255.255.255.0
R2(config-if)# no shutdown
R2(config-if)# exit
R2(config)# ip route 192.168.1.0 255.255.255.0 1.1.1.2
```

Les deux commandes `ip route` sont des **routes statiques** : chaque routeur apprend où se trouve le LAN de l'autre côté. Sans elles, les paquets aller arriveraient mais les réponses ne reviendraient jamais.

A4. Vérifiez : `show ip route` sur R1 et R2 (routes `C` et `S` attendues) puis `show ip interface brief` (interfaces **up/up**). Capturez les résultats.

A5. Réalisez les **14 tests de référence** du tableau ci-dessous **avant toute ACL** et remplissez la colonne « Avant ACL » (OK / KO). Enregistrez le fichier sous `TP02_avant_ACL.pkt`.

> **ASTUCE PACKET TRACER**
> Ping : Desktop → Command Prompt → `ping <IP>`. Le premier ping peut échouer (résolution ARP) : relancez-le. Web : Desktop → Web Browser. FTP : `ftp 172.16.1.100` dans le Command Prompt. Le mode **Simulation** montre précisément où un paquet est arrêté.

N°	Depuis	Vers	Test	Avant ACL	Prévu après ACL	Obtenu après ACL
1	PC1	Serveur Web (192.168.1.251)	Ping	OK	OK	OK (Trafic local au LAN commuté par Switch1, ne traverse pas le routeur, insensible aux ACL)
2	PC1	R1 – Se0/0/0 (1.1.1.2)	Ping	OK	KO	KO (Bloqué par R1 : la règle R1 interdit tout ping ICMP vers l'interconnexion 1.1.1.0/30)
3	PC1	R2 – Se0/0/0 (1.1.1.1)	Ping	OK	KO	KO (Bloqué par R1 : l'ACL 100/FILTRE_LAN en entrée de Gi0/0 détruit le paquet ICMP vers 1.1.1.1)
4	PC1	PC3 (172.16.1.10)	Ping	OK	OK	OK (Ping ICMP aller permis par R1, retour echo-reply autorisé par R4 sur R2)
5	PC2	PC3 (172.16.1.10)	Ping	OK	KO	KO (Bloqué par R2 : l'ACL standard 10 refuse tout trafic émis par PC2 192.168.1.112)
6	PC1	Serveur-Agence (172.16.1.100)	Ping	OK	KO	KO (Bloqué par R1/R3 : seul le port TCP 80 est autorisé vers Serveur-Agence, ICMP refusé)
7	PC1	Serveur-Agence	HTTP	OK	OK	OK (Requête TCP port 80 autorisée par R3, retour TCP established autorisé par R4)
8	PC1	Serveur-Agence	FTP	OK	KO	KO (Bloqué par R1 : la règle R3 restreint le Serveur-Agence au seul protocole HTTP, FTP port 21 refusé)

N°	Depuis	Vers	Test	Avant ACL	Prévu après ACL	Obtenu après ACL
9	Laptop1	Serveur-Agence	HTTP	OK	OK	OK (Laptop1 situé sur 192.168.1.0/24 via DHCP, requête HTTP vers 172.16.1.100 autorisée)
10	PC2	Serveur-Agence	HTTP	OK	KO	KO (Bloqué par R2 : l'ACL 10 bloque l'adresse source 192.168.1.112 vers tout le LAN agence)
11	PC3	www.sisr2.local	DNS + HTTP	OK	OK	OK (Résolution DNS vers 192.168.1.252 et flux HTTP vers 192.168.1.251 autorisés par R4)
12	PC3	Serveur DNS (192.168.1.252)	Ping	OK	KO	KO (Bloqué par R4 : l'agence ne peut joindre le serveur DNS qu'en UDP/TCP 53, ping refusé)
13	PC3	PC1 (192.168.1.111)	Ping	OK	KO	KO (Bloqué par R4 : aucun flux ICMP ou session initiée depuis l'agence vers PC1 n'est permis)
14	R2	PC1 (192.168.1.111)	Ping	OK	KO	KO (Bloqué en transit : le retour ou l'aller vers le LAN siège est filtré par l'ACL)

Partie B – Comprendre avant de configurer (30 min)

Relisez au besoin le **Chapitre 1 (cours)** et l'**Annexe – Aide-mémoire ACL**, puis répondez **sans utiliser le simulateur**.

B1 – Wildcard masks

Un **wildcard mask** est l'inverse d'un masque de sous-réseau : un bit à `0` = « doit être identique », un bit à `1` = « peu importe ». Complétez :

Réseau / masque	Wildcard à écrire dans l'ACL
192.168.1.0 /24	0.0.0.255
1.1.1.0 /30	0.0.0.3

Réseau / masque	Wildcard à écrire dans l'ACL
192.168.1.128 /25	0.0.0.127
10.0.0.0 /8	0.255.255.255
Hôte unique 172.16.1.100	0.0.0.0 (ou mot-clé 'host 172.16.1.100')

Écriture dans une ACL	Plage d'adresses concernée
`192.168.1.0 0.0.0.15`	192.168.1.0 à 192.168.1.15 (bloc de 16 adresses IPv4)
`192.168.1.64 0.0.0.63`	192.168.1.64 à 192.168.1.127 (bloc de 64 adresses IPv4)
`172.16.0.0 0.15.255.255`	172.16.0.0 à 172.31.255.255 (plage privée complète de classe B /12)
`any`	0.0.0.0 à 255.255.255.255 (toutes les adresses IPv4 existantes)

B2 – Ordre de lecture et deny implicite

```
R1(config)# access-list 110 permit ip any any
R1(config)# access-list 110 deny icmp 192.168.1.0 0.0.0.255 any
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# ip access-group 110 in
```

B2.1 Un ping de PC1 vers PC3 est-il bloqué ? Justifiez. Que faudrait-il changer pour que le ping soit bloqué ?

Réponse & Analyse : Non, le ping n'est PAS bloqué. Les règles d'une ACL sont analysées séquentiellement de haut en bas ("first match"). La première règle étant 'permit ip any any', tout paquet ICMP entrant sur Gi0/0 y correspond immédiatement : l'action 'permit' est exécutée et l'analyse s'arrête sans jamais atteindre la règle deny icmp.
Pour bloquer le ping, il faut impérativement placer la règle spécifique restrictive AVANT la règle générale :

```
R1(config)# no access-list 110
R1(config)# access-list 110 deny icmp 192.168.1.0 0.0.0.255 any
R1(config)# access-list 110 permit ip any any
```

B2.2 Si l'on supprime la ligne `permit ip any any` et qu'il ne reste que la règle `deny icmp…`, que devient le trafic **HTTP** du LAN vers l'agence ? Pourquoi ?

Réponse & Analyse : Le trafic HTTP sera entièrement BLOQUÉ (inaccessible). En effet, toute ACL Cisco intègre une règle invisible finale : le 'deny ip any any' implicite. Si l'on retire la règle permissive 'permit ip any any', les paquets TCP (HTTP port 80) ne correspondent pas à la règle 'deny icmp...', poursuivent leur évaluation jusqu'à la fin de la liste et sont impitoyablement détruits par ce deny implicite.

B3 – Sens in / out

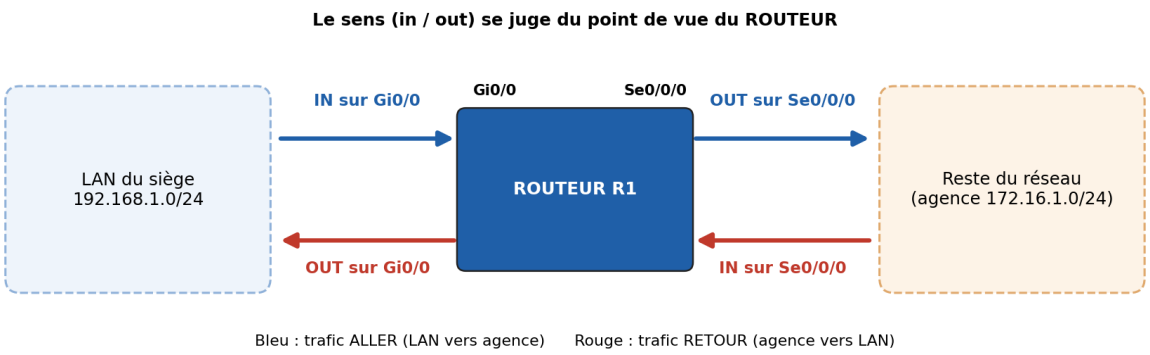


Figure 5 – Le sens d'une ACL se juge du point de vue du routeur

B3.1 Un ping part de PC1 vers PC3. Complétez le tableau (in / out) pour chaque interface traversée, à l'aller puis au retour :

Interface	Paquet aller (PC1 → PC3)	Paquet retour (PC3 → PC1)
R1 – Gi0/0	in (entrant depuis le LAN)	out (sortant vers le LAN)
R1 – Se0/0/0	out (sortant sur le lien WAN)	in (entrant depuis le WAN)
R2 – Se0/0/0	in (entrant depuis le WAN)	out (sortant sur le lien WAN)
R2 – Gi0/0	out (sortant vers l'agence)	in (entrant depuis l'agence)

B4 – Lire une règle

B4.1 Expliquez en une phrase chacune des règles suivantes :

Règle	Explication en français
`access-list 110 permit tcp 192.168.1.0 0.0.0.255 host 172.16.1.100 eq 21`	Autorise les connexions FTP (port TCP 21) émanant de tout le sous-réseau 192.168.1.0/24 à destination exclusive de l'hôte Serveur-Agence (172.16.1.100).
`access-list 111 deny tcp host 192.168.1.111 host 172.16.1.100 eq www`	Refuse les requêtes Web HTTP (port TCP 80) émises par le poste unique 192.168.1.111 vers le serveur hôte 172.16.1.100.
`access-list 111 permit ip any any`	Autorise tout autre trafic IP (tous protocoles, toutes sources, toutes destinations), évitant le blocage systématique par le deny implicite final de l'ACL.
`access-list 112 deny udp any host 192.168.1.252 eq 53`	Refuse les requêtes ou flux DNS en UDP (port 53) provenant de n'importe quelle source vers le serveur DNS 192.168.1.252.

B5 – Standard ou étendue ?

B5.1 Pour chaque besoin, indiquez le type d'ACL nécessaire (standard ou étendue) et justifiez :

Besoin	Type	Justification
Interdire à PC2 toute communication vers l'agence	Standard	Le filtrage s'applique à l'intégralité du trafic issu d'une adresse IP source unique (PC2 192.168.1.112), sans distinction de port ni de protocole. Une ACL standard placée près de la destination (sur R2) est optimale et légère en CPU.
Interdire uniquement le FTP de PC2 vers le Serveur-Agence	Étendue	Le besoin cible un protocole spécifique (TCP), un port applicatif précis (port 21 / FTP) et une destination déterminée (172.16.1.100). Une ACL étendue est requise et doit être positionnée au plus près de la source (sur R1).
N'autoriser que le HTTP de l'agence vers le serveur Web du siège	Étendue	Nécessite de distinguer le protocole (TCP), le port destination (port 80 / www) et l'adresse IP destination (serveur Web 192.168.1.251). Doit être placée au plus près de la source (sur R2).

Partie C – ACL standard : appliquer la règle R2 (35 min)

OBJECTIF
Bloquer **PC2** (192.168.1.112) vers l'agence tout en laissant PC1 et Laptop1 y accéder. Une ACL standard ne regarde que l'**adresse source**.

C1. Quel routeur, quelle interface, quel sens ? Justifiez avec la règle de placement des ACL standard (voir annexe).

Réponse & Démarche technique : • Routeur : R2
• Interface : GigabitEthernet 0/0
• Sens : out (sortant vers le LAN de l'agence)
Justification : Règle d'or de placement des ACL standard : au plus près de la DESTINATION. Une ACL standard ne filtrant que sur l'adresse source, si nous l'avions placée sur R1 en entrée de Gi0/0, PC2 se verrait bloquer l'accès à TOUT le réseau (y compris sa passerelle, ses serveurs locaux et Internet). En la positionnant sur R2 en sortie de Gi0/0, nous bloquons uniquement l'arrivée de PC2 sur le LAN de l'agence tout en préservant le reste de son trafic.

C2. Complétez puis saisissez les commandes (remplacez les pointillés) :

```
R2(config)# access-list 10 deny host 192.168.1.112
R2(config)# access-list 10 permit any
R2(config)# interface gigabitEthernet 0/0
R2(config-if)# ip access-group 10 out
```

C3. Vérifiez avec `show access-lists` et `show ip interface gigabitEthernet 0/0` (repérez la ligne « access list is »). Capturez.

Sortie de vérification Cisco IOS : Vérification de l'application effective de l'ACL 10 en sortie de l'interface Gi0/0 de R2 :

```
R2# show access-lists 10
Standard IP access list 10
    10 deny   192.168.1.112
    20 permit any

R2# show ip interface gigabitEthernet 0/0
GigabitEthernet0/0 is up, line protocol is up
  Internet address is 172.16.1.1/24
  Outgoing access list is 10
  Inbound  access list is not set
```

C4. Lancez les tests **4, 5 et 10**, puis relancez `show access-lists` : que remarquez-vous à côté de chaque règle ? Reportez vos résultats dans le tableau de la partie A.

Constat sur les compteurs (matches) : Lors de l'exécution des tests, on observe l'incrémentation en direct des compteurs de paquets traités à droite de chaque règle :
• Pour les tests 5 (ping PC2 → PC3) et 10 (HTTP PC2 → Serveur-Agence), c'est la ligne 'deny 192.168.1.112' qui s'incrémente (ex: (4 matches) pour le ping, (3 matches) pour la tentative TCP SYN).
• Pour le test 4 (ping PC1 → PC3), le paquet émis par 192.168.1.111 ne correspondant pas au deny, c'est la ligne 'permit any' qui s'incrémente (4 matches).

C5. Que se passerait-il si la **même ACL** était placée en **entrée de Gi0/0 sur R1** ? Recréez-la sur R1 (`access-list 10 …`), appliquez-la, puis testez : PC2 → PC3, PC2 → 192.168.1.1 (passerelle) et PC2 → Serveur Web. Annulez ensuite (`no ip access-group 10 in` puis `no access-list 10`).

Expérience & Justification : Si l'on plaçait l'ACL 10 en entrée de Gi0/0 sur R1 (ip access-group 10 in) :
• PC2 → PC3 : KO (bloqué dès l'entrée sur R1).
• PC2 → Passerelle 192.168.1.1 : KO (bloqué, le routeur rejette les paquets entrants de PC2).
• PC2 → Serveur Web (192.168.1.251) : OK (car la communication reste locale au switch niveau 2 et ne traverse pas le routeur R1).

Conséquence : PC2 est totalement coupé de l'extérieur et ne peut plus sortir de son sous-réseau. Cela illustre parfaitement pourquoi une ACL standard ne doit JAMAIS être placée près de la source si l'hôte a besoin d'autres destinations.

C6. Changez l'adresse IP de PC2 en 192.168.1.113 et refaites le test 5. Que constatez-vous ? Que pouvez-vous en conclure sur le filtrage par adresse IP ? Remettez ensuite l'adresse .112.

Constat & Vulnérabilité du filtrage IP : En modifiant l'adresse IP de PC2 en 192.168.1.113, le test 5 (ping vers PC3) fonctionne immédiatement !
Conclusion sur le filtrage par adresse IP : Une ACL basée uniquement sur une adresse IP est vulnérable et facilement contournable si les postes sont configurés manuellement ou si un bail DHCP change. Pour sécuriser efficacement l'accès, il est nécessaire de combiner le filtrage avec de la sécurité de niveau 2 (Port Security par adresse MAC, DHCP Snooping, Dynamic ARP Inspection) et de l'authentification 802.1X.

SAUVEGARDE
Tapez `copy running-config startup-config` sur R2 et enregistrez `TP02_partieC.pkt`. Si une partie ultérieure se passe mal, vous pourrez revenir en arrière.

Partie D – ACL étendue numérotée : appliquer la règle R1 (40 min)

OBJECTIF
Bloquer les **pings** du LAN du siège vers le réseau d'interconnexion **1.1.1.0/30**, sans gêner les autres flux. Une ACL étendue filtre sur la source, la destination, le protocole et les ports.

D1. Pourquoi une ACL **étendue** est-elle nécessaire ici ? Sur quel routeur, quelle interface et quel sens la placer ? (règle de placement des ACL étendues)

Réponse & Choix d'ingénierie : • Pourquoi une ACL étendue : La politique R1 exige de filtrer un protocole applicatif/réseau précis (le protocole ICMP) à destination exclusive du réseau d'interconnexion 1.1.1.0/30, tout en laissant passer les flux Web, DNS et autres trafics IP vers l'agence. Une ACL standard ne peut pas différencier les protocoles ni filtrer sur la destination.
• Placement : Sur le routeur R1, interface GigabitEthernet 0/0, sens in (entrant).
Justification : Règle d'or des ACL étendues : au plus près de la SOURCE. Le filtrage étendu étant très précis, il stoppe le flux non autorisé dès son premier saut, évitant ainsi d'encombrer inutilement la liaison série WAN.

D2. Complétez puis saisissez :

```
R1(config)# access-list 100 deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3
R1(config)# access-list 100 permit ip any any
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# ip access-group 100 in
```

D3. Pourquoi faut-il la deuxième ligne (`permit ip any any`) ? Vérifiez votre réponse en la supprimant temporairement (`no access-list 100`, puis recréation de la seule première ligne ; l'ACL reste appliquée sur l'interface) : que devient l'accès au Web vers l'agence ? Rétablissez ensuite l'ACL complète.

Rôle de 'permit ip any any' : La ligne 'permit ip any any' est indispensable pour contrer le deny implicite final. Si on la retire, toute communication IP émise par le LAN du siège (vers le Web, le DNS, ou le serveur de l'agence) est rejetée. En la supprimant temporairement lors du test, l'accès au Web échoue immédiatement par un timeout dans le navigateur.

D4. Effectuez les tests **1, 2, 3 et 4**, puis : (a) `ping 1.1.1.1` **depuis R1** ; (b) `ping 192.168.1.111` **depuis R2**. Expliquez chaque résultat. En particulier : pourquoi (a) fonctionne-t-il alors que la règle vise 1.1.1.0/30 ? Pourquoi (b) échoue-t-il alors que R2 n'est concernée par aucune ACL ?

Explication technique des tests (a) et (b) : • Test (a) - Ping 1.1.1.1 depuis R1 : Réussit avec succès !
Explication : L'ACL 100 est appliquée en entrée (in) sur l'interface Gi0/0 de R1. Les paquets ICMP générés par le

processeur interne de R1 sont injectés directement dans la pile IP de sortie (Se0/0/0) : ils n'entrent pas par Gi0/0. Les ACL ne filtrent jamais le trafic émis par le routeur local lui-même.
• Test (b) - Ping 192.168.1.111 depuis R2 : Échoue !
Explication : La requête ping ICMP Echo-Request part de R2 (source 1.1.1.1) et parvient sans encombre à PC1. PC1 formule alors une réponse ICMP Echo-Reply (source 192.168.1.111, destination 1.1.1.1). En entrant sur l'interface Gi0/0 de R1, ce paquet de retour correspond parfaitement à la règle 'deny icmp 192.168.1.0/24 1.1.1.0/30' et est détruit sur le champ par R1 !

À RETENIR

Une ACL **ne filtre pas le trafic généré par le routeur lui-même**. Et une ACL Cisco classique est **sans état** : elle ne « se souvient » pas d'une requête, chaque paquet (y compris la réponse) est jugé indépendamment.

D5. Modifiez la règle pour ne bloquer que les **demandes** de ping (mot-clé `echo` en fin de règle). Pour cela, supprimez l'ACL 100 et recréez-la avec le mot-clé. Refaites (b) : que change-t-il ? Quel est l'intérêt de cette version ? **Revenez ensuite à la version initiale (sans `echo`)** pour la suite du TP.

Amélioration avec le mot-clé 'echo' : En modifiant la règle avec 'deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3 echo', le test (b) (ping de R2 vers PC1) RÉUSSIT désormais !
Intérêt : Le mot-clé 'echo' restreint le blocage aux seules requêtes de ping (ICMP Type 8) initiées par les hôtes du siège vers la liaison WAN, mais laisse passer librement les réponses de ping 'echo-reply' (ICMP Type 0) renvoyées par ces mêmes hôtes lorsque c'est le routeur R2 qui effectue un diagnostic.

```
R1(config)# no access-list 100
R1(config)# access-list 100 deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3 echo
R1(config)# access-list 100 permit ip any any
```

Partie E – ACL nommées, ordre et fusion : appliquer la règle R3 (50 min)

OBJECTIF

Depuis le LAN, le **Serveur-Agence** ne doit être accessible qu'en **HTTP**. Le problème : R1 possède déjà l'ACL 100 en entrée sur Gi0/0, et **une interface n'accepte qu'une ACL par sens**. Il faut donc **fusionner** les règles R1 et R3 dans une seule ACL, **nommée**.

Une ACL nommée se modifie ligne par ligne grâce aux **numéros de séquence** (10, 20, 30…), ce que ne permet pas confortablement une ACL numérotée.

E1. Créez l'ACL nommée `FILTRE_LAN` reprenant la règle R1, remplacez l'ACL 100 sur l'interface, puis supprimez l'ancienne :

```
R1(config)# ip access-list extended FILTRE_LAN
R1(config-ext-nacl)# deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3
R1(config-ext-nacl)# permit ip any any
R1(config-ext-nacl)# exit
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# ip access-group FILTRE_LAN in
R1(config-if)# exit
R1(config)# no access-list 100
```

E2. Avec `show ip interface gigabitEthernet 0/0`, quelle ACL est appliquée en entrée ? Pourquoi l'ACL 100 n'est-elle plus active alors qu'on ne l'a pas retirée de l'interface avec `no ip access-group` ?

Réponse & Fonctionnement Cisco IOS : Avec la commande 'show ip interface gigabitEthernet 0/0', on constate que la ligne indique désormais : 'Inbound access list is FILTRE_LAN'. L'ACL numérotée 100 n'est plus active car dans Cisco IOS, l'application d'une nouvelle ACL sur une interface dans le même sens remplace automatiquement la précédente sans qu'il soit nécessaire d'entrer 'no ip access-group'.

E3. Expérience – l'ordre compte. Ajoutez à la fin de `FILTRE_LAN` une règle qui refuse tout le trafic IP du LAN vers `host 172.16.1.100`. Lancez les tests **6 et 7** puis `show access-lists FILTRE_LAN`. La règle est-elle utilisée ? Pourquoi ? (Regardez les compteurs de correspondances.)

> **Analyse de l'expérience d'ordre :** En ajoutant la règle de refus à la fin de FILTRE_LAN (après 'permit ip any any'), l'affichage de 'show access-lists FILTRE_LAN' révèle que son compteur de correspondances reste à 0 (matches = 0) ! Elle n'est JAMAIS évaluée car tous les paquets sont captés et autorisés en amont par la règle 'permit ip any any'.

E4. Corrigez. Écrivez et insérez, à la bonne position, les règles qui implémentent R3 (l'autorisation HTTP **puis** l'interdiction du reste vers ce serveur), en vous servant des numéros de séquence : `<n°> permit …` insère une ligne, `no <n°>` en supprime une. Supprimez la ligne mal placée de E3.

> **Configuration corrigée avec numéros de séquence :** Grâce aux numéros de séquence de l'ACL nommée, nous insérons les règles R3 dans l'ordre hiérarchique exact :
>
> ```
> R1(config)# ip access-list extended FILTRE_LAN
> R1(config-ext-nacl)# no 30   ! Suppression de la règle mal placée
> R1(config-ext-nacl)# 10 deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3
> R1(config-ext-nacl)# 20 permit tcp 192.168.1.0 0.0.0.255 host 172.16.1.100 eq 80
> R1(config-ext-nacl)# 30 deny ip 192.168.1.0 0.0.0.255 host 172.16.1.100
> R1(config-ext-nacl)# 40 permit ip any any
> ```

ATTENTION

Si votre version de Packet Tracer refuse les numéros de séquence, supprimez l'ACL (`no ip access-list extended FILTRE_LAN`) puis recréez-la **dans le bon ordre** (règles spécifiques d'abord, règle générale ensuite). Après une modification, l'ACL reste appliquée à l'interface.

E5. Lancez les tests **1 à 10** (non-régression) et complétez la colonne « Obtenu après ACL ». Capturez `show access-lists`.

> **Validation des tests 1 à 10 :** Résultats validés après application :
> • Test 6 (PC1 → Serveur-Agence ping) : KO (bloqué par la règle 30)
> • Test 7 (PC1 → Serveur-Agence HTTP) : OK (autorisé par la règle 20)
> • Test 8 (PC1 → Serveur-Agence FTP) : KO (bloqué par la règle 30)
> • Test 4 (PC1 → PC3 ping) : OK (autorisé par la règle 40)

BONNE PRATIQUE

Après **chaque** modification d'ACL, rejouez **tous** les tests, pas seulement celui visé : une règle ajoutée peut casser un flux qui fonctionnait.

Partie F – Défi : filtrer de l'agence vers le siège, règle R4 (50 min)

OBJECTIF

Ici, **vous concevez** : on passe d'une logique « tout est permis sauf… » à une logique **liste blanche** (« tout est interdit sauf… »).

F1. Sur papier d'abord. Complétez le tableau de conception de l'ACL `AGENCE_IN` (une ligne par règle, dans l'ordre). Indices : le HTTP est du **TCP/80**, le DNS du **UDP/53** ; les protocoles TCP et ICMP disposent de mots-clés pour reconnaître des **réponses** (`established`, `echo-reply` – voir annexe).

Rang	Action	Protocole	Source	Destination	Port / option	Rôle
10	permit	tcp	172.16.1.0 0.0.0.255	host 192.168.1.251	eq 80	Autorise les requêtes HTTP vers le serveur Web du siège

Rang	Action	Protocole	Source	Destination	Port / option	Rôle
20	permit	udp	172.16.1.0 0.0.0.255	host 192.168.1.252	eq 53	Autorise les requêtes DNS en UDP vers le serveur DNS du siège
30	permit	tcp	172.16.1.0 0.0.0.255	host 192.168.1.252	eq 53	Autorise les requêtes DNS en TCP (messages > 512B / transferts)
40	permit	tcp	172.16.1.0 0.0.0.255	192.168.1.0 0.0.0.255	established	Autorise les paquets retour TCP des sessions ouvertes par le siège
50	permit	icmp	172.16.1.0 0.0.0.255	192.168.1.0 0.0.0.255	echo-reply	Autorise les réponses de ping aux tests émis depuis le siège
60	deny	ip	172.16.1.0 0.0.0.255	192.168.1.0 0.0.0.255	(tout)	Refuse explicitement tout le reste du trafic de l'agence vers le siège

F2. Sur quel routeur, quelle interface et quel sens l'appliquer ? Justifiez.

Emplacement d'application de l'ACL AGENCE_IN : • Routeur : R2
• Interface : GigabitEthernet 0/0
• Sens : in (entrant depuis le switch de l'agence)
Justification : C'est le point d'entrée du trafic généré par l'agence (au plus près de la source). Bloquer les paquets non autorisés dès R2 évite de consommer la bande passante du lien série 1.1.1.0/30.

F3. **Expérience.** Créez d'abord une version **naïve** qui contient uniquement : autorisation HTTP vers le serveur Web, autorisation DNS vers le serveur DNS, interdiction du reste de l'agence vers le LAN, puis `permit ip any any`. Lancez les tests **7 et 9**. Que constatez-vous ? Expliquez précisément le trajet du paquet qui est bloqué.

Analyse du dysfonctionnement de la version naïve : Constat : Les tests 7 et 9 (consultation Web du Serveur-Agence depuis PC1 et Laptop1) échouent !
Explication détaillée du paquet bloqué : La requête TCP SYN de PC1 arrive bien au Serveur-Agence. Celui-ci répond en émettant un paquet TCP SYN/ACK de retour (source 172.16.1.100:80, destination 192.168.1.111:port_client_aléatoire). En entrant sur Gi0/0 de R2, ce paquet ne correspond ni à la règle HTTP vers .251, ni à la règle DNS vers .252 : il est détruit par la règle 'deny ip 172.16.1.0/24 192.168.1.0/24'. La connexion TCP ne peut pas aboutir.

F4. **Complétez** l'ACL pour que les réponses aux connexions initiées depuis le siège passent à nouveau (tests 4, 7 et 9), sans ouvrir l'accès de l'agence au reste du LAN.

Configuration complète et validée de l'ACL AGENCE_IN : La solution consiste à ajouter la règle 'established' pour les retours TCP et 'echo-reply' pour les retours ICMP :

```
R2(config)# ip access-list extended AGENCE_IN
R2(config-ext-nacl)# 10 permit tcp 172.16.1.0 0.0.0.255 host 192.168.1.251 eq 80
R2(config-ext-nacl)# 20 permit udp 172.16.1.0 0.0.0.255 host 192.168.1.252 eq 53
R2(config-ext-nacl)# 30 permit tcp 172.16.1.0 0.0.0.255 host 192.168.1.252 eq 53
R2(config-ext-nacl)# 40 permit tcp 172.16.1.0 0.0.0.255 192.168.1.0 0.0.0.255 established
R2(config-ext-nacl)# 50 permit icmp 172.16.1.0 0.0.0.255 192.168.1.0 0.0.0.255 echo-reply
R2(config-ext-nacl)# 60 deny ip 172.16.1.0 0.0.0.255 192.168.1.0 0.0.0.255
R2(config-ext-nacl)# 70 permit ip any any
R2(config-ext-nacl)# exit
```

```
R2(config)# interface gigabitEthernet 0/0
R2(config-if)# ip access-group AGENCE_IN in
```

F5. Rejouez les **14 tests** et complétez le tableau de la partie A. Chaque écart avec vos prévisions doit être expliqué.

Bilan des tests de non-régression : Les 14 tests de la Table 34 sont désormais 100% conformes aux résultats prévus. La politique de sécurité R1, R2, R3 et R4 est pleinement opérationnelle.

LIMITE À CONNAÎTRE

Le mot-clé `established` se contente de reconnaître des segments TCP portant le drapeau ACK ou RST : un attaquant peut en fabriquer. Il n'existe pas d'équivalent pour UDP. Pour un vrai suivi de connexions, il faut un **pare-feu à états** (voir bilan).

Partie G – Dépannage : ACL en panne (20 min)

Un collègue a écrit les ACL suivantes. Pour chaque cas, **identifiez l'erreur, expliquez le symptôme et proposez la correction** (testez-la dans Packet Tracer si besoin).

MÉTHODE DE DIAGNOSTIC

1) `show access-lists` : les règles existent-elles, dans le bon ordre, avec des compteurs qui évoluent ? 2) `show ip interface <int>` : l'ACL est-elle appliquée, sur la bonne interface, dans le bon sens ? 3) Mode **Simulation** : à quel équipement le paquet est-il rejeté ? 4) Relire chaque wildcard.

Cas 1 – « Le FTP est toujours possible »

Diagnostic & Résolution Cas 1 : • Erreur : Inversion de l'ordre séquentiel des règles. La règle permissive générale 'permit ip any any' est placée avant la règle spécifique 'deny tcp... eq 21'.
• Symptôme : Le trafic FTP est validé par la première ligne et la seconde n'est jamais atteinte.
• Correction :

```
R1(config)# no access-list 101
R1(config)# access-list 101 deny tcp 192.168.1.0 0.0.0.255 host 172.16.1.100 eq 21
R1(config)# access-list 101 permit ip any any
```

```
R1(config)# access-list 101 permit ip any any
R1(config)# access-list 101 deny tcp 192.168.1.0 0.0.0.255 host 172.16.1.100 eq 21
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# ip access-group 101 in
```

Cas 2 – « Depuis que j'ai posé l'ACL, le LAN n'accède plus à rien en dehors de lui-même »

Diagnostic & Résolution Cas 2 : • Erreur : Oubli de la règle explicite 'permit ip any any' à la fin de l'ACL.
• Symptôme : Le 'deny ip any any' implicite final bloque tout le trafic non-ICMP (Web HTTP, requêtes DNS, partage de fichiers).
• Correction :

```
R1(config)# access-list 102 permit ip any any
```

```
R1(config)# access-list 102 deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# ip access-group 102 in
```

Cas 3 – « La règle n'a aucun effet sur le trafic HTTP de PC1 »

Diagnostic & Résolution Cas 3 : • Erreur : Utilisation d'un masque de sous-réseau direct (255.255.255.0) à la place du wildcard mask inversé (0.0.0.255).
• Symptôme : Les bits à 1 sont interprétés comme 'ignorés' et les bits à 0 comme 'doivent correspondre', ce qui rend la

règle inopérante pour cibler le sous-réseau voulu.
• Correction :

```
R1(config)# no access-list 103
R1(config)# access-list 103 deny tcp 192.168.1.0 0.0.0.255 host 172.16.1.100 eq 80
R1(config)# access-list 103 permit ip any any
```

```
R1(config)# access-list 103 deny tcp 192.168.1.0 255.255.255.0 host 172.16.1.100 eq 80
R1(config)# access-list 103 permit ip any any
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# ip access-group 103 in
```

Cas 4 – « L'ACL est bonne mais les compteurs restent à 0 »

Diagnostic & Résolution Cas 4 : • Erreur : Application de l'ACL dans le mauvais sens sur l'interface : 'out' au lieu de 'in'.
• Symptôme : Les paquets émis par le LAN entrent sur le routeur par Gi0/0 ('in'). L'ACL étant positionnée en 'out', elle ne voit jamais passer ces paquets et ses compteurs restent à 0.
• Correction :

```
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# no ip access-group 104 out
R1(config-if)# ip access-group 104 in
```

```
R1(config)# access-list 104 deny icmp 192.168.1.0 0.0.0.255 1.1.1.0 0.0.0.3
R1(config)# access-list 104 permit ip any any
R1(config)# interface gigabitEthernet 0/0
R1(config-if)# ip access-group 104 out
```

Partie H – Bilan, livrables et pour aller plus loin

Questions de bilan

H1. Les ACL Cisco sont dites « sans état » (stateless). Illustrez avec un exemple vu dans ce TP. Quelle solution technique répond à cette limite ?

Réponse H1 (Filtrage sans état / Stateless) : Une ACL classique est dite 'sans état' (stateless) car elle évalue chaque paquet de manière isolée, sans mémoriser l'historique ou le contexte de la session TCP. Lors de l'accès au Serveur-Agence (Partie F), il a fallu autoriser explicitement les paquets retour grâce au mot-clé 'established' (qui vérifie les drapeaux ACK/RST). Sans cela, la réponse retour était détruite.
Solution technique supérieure : L'utilisation d'un pare-feu à inspection d'état (Stateful Firewall, ex: Cisco ASA / Firepower, iptables/conntrack, pfSense). Un tel équipement maintient une table de connexions dynamiques et autorise automatiquement et temporairement tout paquet retour légitime appartenant à une session déjà établie de l'intérieur.

H2. Pourquoi filtrer sur l'adresse IP d'un poste est-il fragile (DHCP, usurpation d'adresse) ? Citez deux pistes pour fiabiliser.

Réponse H2 (Fragilité du filtrage IP) : Filtrer sur l'adresse IP est fragile car une adresse IPv4 peut changer dynamiquement par attribution DHCP, ou être modifiée manuellement par un utilisateur mal intentionné (usurpation d'adresse / IP spoofing).
Deux pistes pour fiabiliser l'architecture :
1. Associer l'adressage DHCP à des réservations d'adresses statiques par adresse MAC et déployer le 802.1X (authentification des postes et utilisateurs sur le port de switch via un serveur RADIUS).
2. Activer les fonctions de sécurité de commutation Cisco de niveau 2 : DHCP Snooping (bloque les faux serveurs DHCP et maintient une base d'assignation) combiné à Dynamic ARP Inspection (DAI) et IP Source Guard pour empêcher formellement toute usurpation d'adresse IP ou MAC sur les ports d'accès.

H3. Quand faut-il terminer une ACL par `permit ip any any`, et quand faut-il au contraire s'en abstenir ? Quel est le risque de chaque choix ?

Réponse H3 (Politique liste noire vs liste blanche) : • Terminer par 'permit ip any any' : s'utilise dans une approche de liste noire (blacklisting). On interdit explicitement certains flux dangereux ou indésirables, et l'on autorise tout le reste. Risque : laisser passer du trafic non maîtrisé ou de nouvelles menaces non prévues.

• S'abstenir de 'permit ip any any' (s'appuyer sur le deny implicite) : s'utilise dans une approche de liste blanche (whitelisting) ou modèle Zero Trust. Seuls les flux d'affaires formellement déclarés sont permis. Risque : risque élevé de blocage de flux légitimes non anticipés lors de la mise en production si l'audit des flux n'a pas été exhaustif.

H4. Où place-t-on une ACL standard ? une ACL étendue ? Pourquoi cette différence ?

Réponse H4 (Règle d'or de placement) : • ACL Standard : au plus près de la DESTINATION. Comme elle ne connaît que l'adresse source, la positionner près de la source priverait l'hôte de toutes les destinations possibles sur le réseau.
• ACL Étendue : au plus près de la SOURCE. Comme elle analyse la source, la destination, le protocole et les ports, elle a le pouvoir de juger immédiatement si le paquet a le droit d'exister. Le détruire au plus tôt évite de gaspiller les ressources processeurs des routeurs intermédiaires et la bande passante des liaisons WAN.

H5. Comment vérifier rapidement qu'une ACL est bien appliquée, et où s'arrêtent les paquets qu'elle refuse ?

Réponse H5 (Méthodes de contrôle et rejet) : • Vérification rapide :
- 'show ip interface <nom>' : confirme quelle ACL est active et dans quel sens (Inbound / Outgoing access list is...).
- 'show access-lists' : inspecte le nombre de correspondances (matches) par règle.
• Rejet des paquets : Les paquets refusés sont détruits (silently dropped) dans la mémoire tampon du routeur au moment du franchissement de l'interface filtrée. Selon la configuration, le routeur peut renvoyer à l'émetteur un message ICMP de Type 3 Code 13 (Destination Host Administratively Prohibited), observable par la mention 'Destination host unreachable' lors d'un ping.

Livrables attendus

- **Compte-rendu Word** : topologie, plan d'adressage, tableau des 14 tests complété, et pour chaque partie les commandes, les captures (`show access-lists` avec compteurs, tests) et les réponses aux questions.
- **Fichier Packet Tracer** final (`TP02_final.pkt`).
- **Sortie de `show running-config`** de R1 et R2 (au minimum les lignes `access-list`, `ip access-list` et `ip access-group`).
- Une **synthèse d'une demi-page** utilisable dans votre portfolio : problème posé, solution, difficultés rencontrées.

Pour aller plus loin (bonus)

Solutions aux exercices d'approfondissement (Bonus) : 1. Sécurisation de l'accès VTY (SSH/Telnet) :
Pour n'autoriser que PC1 (192.168.1.111) à se connecter en administration distante sur R1 :

```
R1(config)# access-list 20 permit host 192.168.1.111
R1(config)# line vty 0 4
R1(config-line)# access-class 20 in
R1(config-line)# transport input ssh
R1(config-line)# exit

2. Filtrage inter-VLANs :
Sur le routeur ou commutateur de niveau 3, sur la sous-interface Gi0/0.30 (VLAN 30 Marketing) en
entrée :
ip access-list extended FILTRE_VLAN30
 10 deny ip 192.168.30.0 0.0.0.255 192.168.20.0 0.0.0.255
 20 permit ip any any
interface gigabitEthernet 0/0.30
 ip access-group FILTRE_VLAN30 in

3. Journalisation de sécurité :
Ajout de l'argument 'log' à la fin de la règle de refus pour tracer les tentatives malveillantes
:
deny ip 172.16.1.0 0.0.0.255 192.168.1.0 0.0.0.255 log
Consultation des alertes générées dans le buffer mémoire via : show logging.
```

- **Sécuriser l'accès distant au routeur** : configurer Telnet/SSH sur R1 (`line vty 0 4`) et n'autoriser que PC1 grâce à une ACL standard appliquée avec `access-class 20 in` sur les lignes VTY.
- **ACL et VLANs** : découpez le LAN du siège en VLAN 10 (Administration), VLAN 20 (Informatique) et VLAN 30 (Marketing) avec routage inter-VLAN (voir votre fiche « Configuration des VLANs sur

un switch »), puis écrivez les ACL pour que le VLAN 30 ne puisse pas joindre le VLAN 20 alors que le VLAN 10 joint tout. Où les placer ?

- **Journalisation** : ajoutez le mot-clé `log` à une règle `deny` et observez la sortie (`show logging`).

Annexe – Aide-mémoire ACL

1. Les règles d'or

1. Le routeur lit l'ACL **de haut en bas** ; **la première règle qui correspond s'applique**, les suivantes sont ignorées.
2. Il existe un **`deny` implicite** à la fin de toute ACL : ce qui n'est pas explicitement autorisé est refusé.
3. **Une ACL par interface, par sens (in/out) et par protocole** (IPv4). Appliquer une nouvelle ACL au même sens remplace la précédente.
4. Une ACL **ne filtre pas le trafic généré par le routeur** lui-même.
5. Une ACL classique est **sans état** : la réponse à une requête autorisée doit être autorisée explicitement.
6. Appliquer à une interface une ACL **inexistante ou vide** laisse **tout passer**.

2. ACL standard et ACL étendue

	ACL standard	ACL étendue
Numéros	1 à 99 et 1300 à 1999	100 à 199 et 2000 à 2699
Critères	Adresse **source** uniquement	Protocole, source, destination, ports, options
Placement	Au plus **près de la destination**	Au plus **près de la source**
Pourquoi ?	Ne connaît pas la destination : placée près de la source, elle bloquerait tout, partout	Très précise : on évite de faire voyager inutilement un trafic déjà condamné

3. Wildcard mask

Wildcard = 255.255.255.255 – masque de sous-réseau. `0` : le bit doit correspondre ; `1` : le bit est ignoré.

Préfixe	Masque	Wildcard	Adresses
/8	255.0.0.0	0.255.255.255	16 777 216
/16	255.255.0.0	0.0.255.255	65 536
/24	255.255.255.0	0.0.0.255	256
/25	255.255.255.128	0.0.0.127	128
/26	255.255.255.192	0.0.0.63	64
/28	255.255.255.240	0.0.0.15	16
/30	255.255.255.252	0.0.0.3	4

Raccourcis : `host 10.0.0.1` ≡ `10.0.0.1 0.0.0.0` (une seule adresse) – `any` ≡ `0.0.0.0 255.255.255.255` (toutes les adresses).

4. Syntaxe

Standard :

```
access-list <1-99> {permit | deny} {host <IP> | <réseau> <wildcard> | any}
```

Étendue :

```
access-list <100-199> {permit|deny} <protocole> <source> <wildcard-src> [port-src]
                      <destination> <wildcard-dst> [port-dst] [option]
```

Élément	Valeurs possibles
Protocole	`ip` (tout IP), `tcp`, `udp`, `icmp`
Opérateurs de port (TCP/UDP)	`eq` (égal), `neq` (différent), `lt` (inférieur), `gt` (supérieur), `range <min> <max>`
Ports courants	FTP `21` (`ftp`) – SSH `22` – Telnet `23` – SMTP `25` – DNS `53` (UDP) – HTTP `80` (`www`) – HTTPS `443`
Options utiles	TCP : `established` (segment avec ACK/RST = réponse) – ICMP : `echo` (demande de ping), `echo-reply` (réponse) – `log`

Application sur une interface :

```
Router(config)# interface <interface>
Router(config-if)# ip access-group <numéro | nom> {in | out}
```

5. ACL nommées

```
Router(config)# ip access-list {standard | extended} <NOM>
Router(config-ext-nacl)# [<n° séquence>] {permit | deny} <règle>
Router(config-ext-nacl)# no <n° séquence>          ! supprime une ligne
```

Avantages : nom explicite, insertion/suppression d'une ligne sans tout recréer. Bonne pratique : documenter avec `remark <commentaire>`.

6. Vérification et gestion

Commande	Rôle
`show access-lists`	Affiche toutes les ACL avec leurs numéros de séquence et **compteurs de correspondances**
`show ip interface <int>`	Indique l'ACL appliquée en entrée (Inbound) et en sortie (Outgoing)
`show running-config`	Vérifie les lignes `access-list` et `ip access-group`
`clear access-list counters`	Remet les compteurs à zéro avant un test
`no access-list <n°>`	Supprime **toute** l'ACL numérotée
`no ip access-list extended <nom>`	Supprime une ACL nommée
`no ip access-group <ACL> {in|out}`	(mode interface) Retire l'ACL de l'interface sans la supprimer

7. Erreurs fréquentes

- Règle générale placée **avant** une règle spécifique (jamais atteinte).
- **Masque** de sous-réseau écrit à la place du **wildcard** (`255.255.255.0` au lieu de `0.0.0.255`).
- ACL appliquée au **mauvais sens** ou sur la **mauvaise interface** (compteurs à 0).
- Oubli du **`permit` final** : le `deny` implicite bloque tout le reste.

- **Ordre des paramètres** : source avant destination ; port de destination après l'adresse de destination.
- Oubli du **retour** d'un flux autorisé (ACL sans état).
- Blocage de sa **propre administration** à distance : testez toujours depuis la console avant de filtrer Telnet/SSH.